

1

Red Hat Enterprise Linux

Instalação segura, LVM sobre LUKS, SSH endurecido e automação em Shell

Grupo 1 **Matheus Silva** – RM: 572335; **Davi Almeida** – RM: 569447; **Joao Vitor** – RM: 568847; **Gabriel de Oliveira** – RM: 569695; **Ni colas Quadrelli** – RM: 568869;
Melquem Lameque – RM: 573428

Sistemas Operacionais Linux Cibersegurana FIAP 2026

Professor: Fabio Pires Turma: 1TDCPF

Seis blocos em trinta minutos

- | | | |
|---|--|-------|
| 1 | De onde vem o RHEL — e o que se compra | 6 min |
| 2 | O esquema de particionamento e por quê | 5 min |
| 3 | Instalação com LVM sobre LUKS | 7 min |
| 4 | SSH fora do padrão — e pós-quântico | 5 min |
| 5 | ssh-audit-harden.sh em ação | 4 min |
| 6 | Cinco perguntas para vocês | 3 min |

De um catálogo de software a US\$ 34 bilhões

O nome: o boné vermelho de lacrosse da Cornell que Marc Ewing usava na Carnegie Mellon.



A virada de 2002: o código continua aberto; o que passa a ser vendido é a versão estável com suporte.

Uma família, três papéis



E os clones gratuitos?

- 2004** CentOS: RHEL recompilado a partir do código-fonte, sem a marca e sem suporte
- 2014** O projeto CentOS passa a ser patrocinado pela Red Hat
- 2020** Dezembro: CentOS Linux vai acabar em 2021; o foco vira o Stream. Surgem Rocky Linux e AlmaLinux
- 2023** Junho: o código-fonte público ligado ao RHEL passa a sair só pelo CentOS Stream

RHEL 10 • maio de 2025

Codiname Coughlan. Segundo a Red Hat, a primeira distribuição corporativa com a criptografia pós-quântica padronizada pelo NIST.

Instalamos o 10.2 — e testamos essa promessa no bloco 4.

Se o código é aberto, o que se compra?

Não é licença de uso.

É um contrato de serviço continuado.

No nosso servidor, sem registro:

"Não há repositórios habilitados".

Depois dele: 147 pacotes e 3 chaves GPG.

● Errata testada

RHSA • RHBA • RHEA entregues pelo repositório

● Suporte com SLA

Self-support • Standard • Premium

● Certificação

Hardware e software homologados pelo fornecedor

● Garantias de PI

Indenização contratual de propriedade intelectual

Dez anos não é marketing, é arquitetura

≈ 5 ANOS

Full Support

correção, segurança,
hardware novo, funcionalidade

≈ 5 ANOS

Maintenance Support

apenas segurança e bugs
de alta prioridade

ALÉM DOS 10

Extended Life Phase

suporte limitado • extensões
(ELC) vão além

Backport: a correção vem, a versão não muda

Um scanner que compara apenas o número da versão acusa falso positivo em RHEL.
A fonte de verdade é o mapeamento CVE → errata da Red Hat.

10

anos de ciclo • RHEL 8, 9 e 10

Fonte: política de ciclo de vida da Red Hat, consultada em <data>

Insights: risco em escala — a que preço?

Advisor

Vulnerability

Compliance

Patch

Malware

Drift

Serviços incluídos na subscrição, sem custo adicional

A pergunta que fizemos: o que exatamente sai da máquina?

- Inspeção local do payload antes do envio
- Ofuscação de endereço IP e hostname • redação de arquivos e palavras-chave
- No nosso servidor, o login já dizia: “Register this system with Red Hat Lightspeed”

Desenhado antes de instalar qualquer coisa

sda1 • 1 GB • FAT32

/boot/efi

sda2 • 1 GB • xfs

/boot

FORA da criptografia

Risco residual

O GRUB precisa ler kernel e initramfs antes de existir chave — os dois ficam em claro.

sda3 • ~58 GB • LUKS2 — container criptografado

VG vg_sistema

lv_root

15 G • /

lv_home

10 G • /home

lv_var

8 G • /var

lv_tmp

3 G • /tmp

lv_varlog

5 G • /var/log

lv_swap

4 G • swap

lv_vartmp

3 G • /var/tmp

~10 G LIVRES

snapshots e emergência

Um único container • uma passphrase • todo LV novo já nasce criptografado

Cada opção bloqueia um ataque

Montagem	Opções	Ataque bloqueado
/tmp /var/tmp	nodev, nosuid, noexec	Payload gravado em diretório mundialmente gravável — o vetor mais clássico de escalonamento
/home	nodev, nosuid	Usuário comum criando um binário SUID dentro do próprio diretório
/var/log	nodev, nosuid, noexec	Área de log virando ponto de staging; protege a integridade da trilha
/boot /var	nodev (+ nosuid no /boot)	Crescimento de dados de serviço; proteção da área de boot

Aplicadas à mão: o instalador não põe nenhuma dessas opções. E a literatura avisa de um conflito — que testamos no próximo slide.

Testamos. E a prática contradisse a teoria.

```
$ /tmp/teste.sh  
Permissão negada  
  
$ bash /tmp/teste.sh  
executou
```

**noexec impede executar o arquivo.
Não impede chamar o interpretador.**

Quem executa é o bash, que tem permissão — não o arquivo. Controle real, com limite conhecido.

O conflito que a literatura previu — e não aconteceu

Guias avisam: noexec em /var/tmp quebra o dnf.

Testamos: 147 pacotes atualizados + reinstall bash → nenhuma falha. Decisão: manter, com remontagem documentada como contingência.

Um checkbox separa os dois esquemas



LUKS sobre LVM

Criptografar marcado em cada volume lógico

- Vários containers independentes
- Várias passphrases no boot
- Metadados do volume group expostos



LVM sobre LUKS

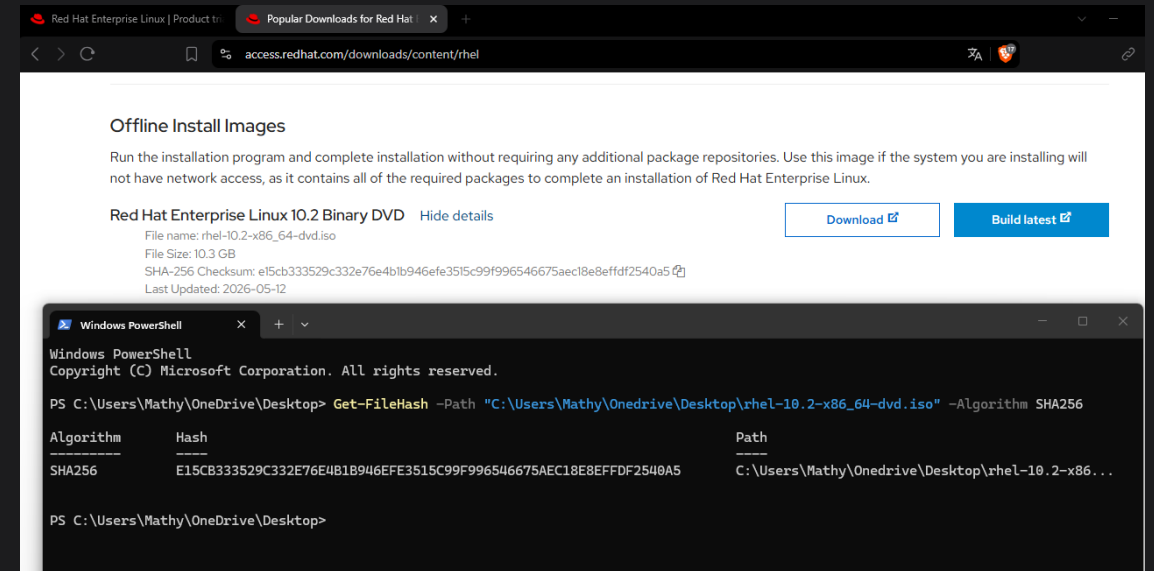
Criptografar marcado NO GRUPO DE VOLUME

- Um container, uma passphrase
- Todo LV novo já nasce criptografado
- Metadados do VG dentro da criptografia

Não existe conversão simples entre os dois. Errar aqui significa reinstalar.

Instalação em sete decisões

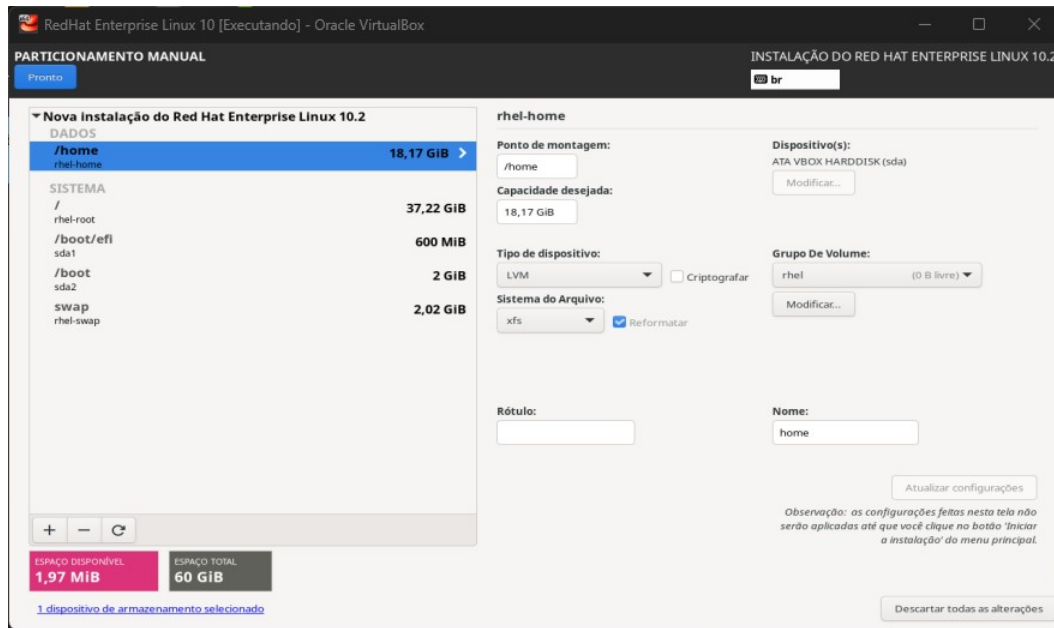
- 1 Seleção de programas: Instalação mínima
- 2 Personalizado — “Criptografar meus dados” some
- 3 /boot/efi e /boot fora do LUKS
- 4 Grupo de volume → Modificar → Criptografar**
- 5 Capacidade sempre preenchida
- 6 VG: “Tão grande quanto possível” só no fim
- 7 Passphrase sem acento • Sumário de alterações



Passo 0 — antes de instalar

O SHA-256 da ISO calculado no Windows (Get-FileHash) é igual ao publicado no portal da Red Hat.

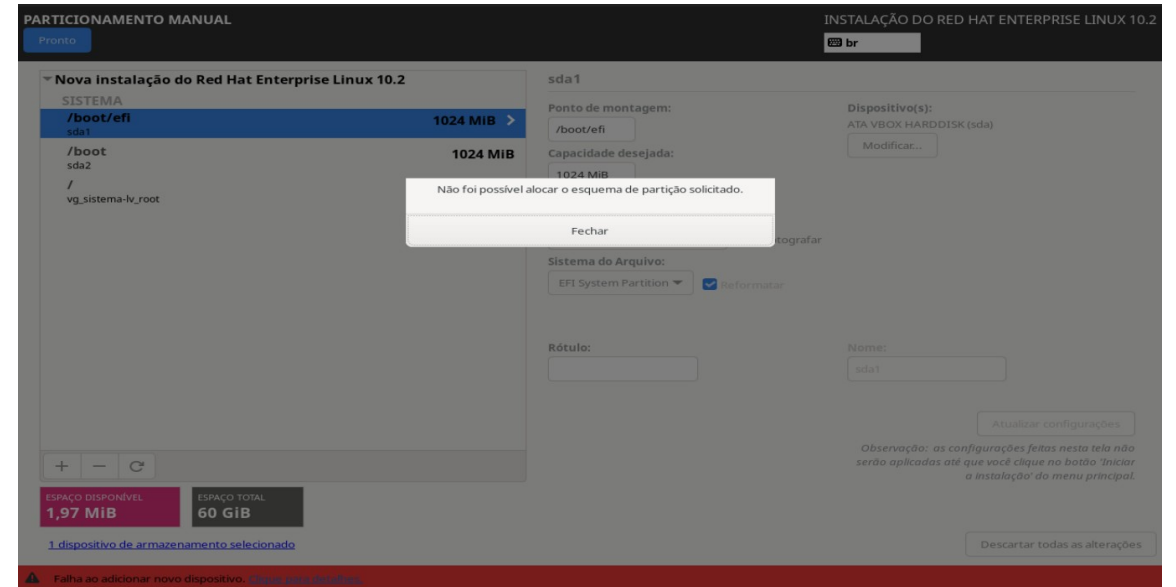
O instalador propõe o contrário



Proposta automática

/ com 37 GiB e /home com 18 GiB. Espaço livre: 1,97 MiB. Nada de /tmp, /var ou /var/log separados — nenhuma opção de montagem possível.

Prints da primeira tentativa (16/09). O esquema final — sete volumes lógicos e ~10 GiB livres no VG — está no slide 8.



Capacidade em branco

O primeiro volume leva o disco inteiro e o seguinte falha: “Não foi possível alocar o esquema de partição solicitado”.

A prova: um container, o VG dentro

```
$ lsblk -f
sda3                                crypto_LUKS
└─luks-abd2ecaa...                  crypt
   ├─vg_sistema-lv_root             /
   ├─vg_sistema-lv_var              /var
   └─... 7 volumes

$ sudo cryptsetup luksDump /dev/sda3
Version 2 · aes-xts-plain64 · 512 bits
PBKDF argon2id

$ sudo vgs
vg_sistema  57,98g  VFree 9,98g

$ getenforce
Enforcing
```

✓ Um único nó crypt

o volume group vive dentro do container

✓ LUKS2 • argon2id

AES-256 em XTS: por isso 512 bits de chave

✓ SELinux Enforcing

do início ao fim, nunca desligado

KDUMP em automático — com o disco cifrado

O problema

Após um crash, o kernel de captura grava a memória em /var/crash — dentro do LUKS. Ninguém digita a senha, e o argon2id pediria ~1,3 GB de reserva em vez de 256 MB.



*Kdump may require extra setup
for encrypted devices.*

aviso do instalador

O que o RHEL 10 configurou

No boot, o systemd guarda a chave de volume no keyring do kernel. O kdump a reaproveita no kernel de captura: sem digitar senha e sem reservar memória extra para o argon2id.

Decisão: manter em automático. O dump de um crash é evidência para investigar a falha.

```
$ sudo kdumpctl status ; sudo kdumpctl showmem
kdump: Kdump is operational
kdump: Notice: No vmcore creation test performed!
kdump: Reserved 256MB memory for crash kernel
$ cat /etc/crypttab
luks-abd2ecaa... none discard,x-initrd.attach,link-volume-key=@u::%logon:kdump-cryptsetup:vk-abd2ecaa...
```

Limite honesto: nenhum crash foi provocado — o próprio kdump avisa. A chave fica na memória reservada, como já fica na do kernel com o disco aberto.

Fonte: “Support kdump with LUKS encryption by reusing LUKS volume keys” (patches da Red Hat, LWN) • evidências 20-segundo-disco.txt e 32-kdump.txt (23/09)

Segundo disco: o ciclo de vida do LVM

luksFormat

›

pvcreate

›

vgextend

›

lvcreate

›

lvextend

›

xfs_growfs

20 GB adicionados depois da instalação — também em LUKS2, desbloqueio por arquivo de chave

57,98 → 77,96 GiB

VG com dois volumes físicos cifrados

8 → 13 GiB

lv_dados crescido montado e em uso,
inteiro no disco novo

0,01%

snapshot de / ocupado — cópia-na-escrita

pvcreate direto em /dev/sdb deixaria um quarto do VG em claro • XFS só cresce: lvreduce em XFS destrói dados

O padrão aceita senha e permite root

O OpenSSH não vem permissivo por descuido — vem permissivo para funcionar em qualquer lugar.

● Chave ed25519

● Senha desabilitada

● PermitRootLogin no

● Porta 6969

● Rótulo SELinux

● AllowGroups

● MaxAuthTries 3

● Cockpit fora do firewall

● Política de criptografia

● firewalld com limite

● Banner legal

● LogLevel VERBOSE

Sair do padrão é trabalho manual — e é exatamente esse trabalho que se cobra de um administrador.

A ordem não é estilo, é sobrevivência

1

```
semanage port -a -t ssh_port_t -p tcp 6969
```

Sem o rótulo, o sshd não abre a porta com SELinux em Enforcing

2

```
firewall-cmd --add-rich-rule ... limit value="10/m"
```

Só a rich rule • serviços ssh e cockpit removidos

3

Port 6969 em 01-hardening-grupo1.conf

Último passo — e o 01- no nome importa (bloco 5)

4

```
sshd -t && systemctl restart sshd
```

Validar antes; restart porque a porta mudou

Regra de ouro

Nunca feche a sessão atual antes de validar a nova em outra sessão.

O console do VirtualBox é a via de socorro.

Em produção, errar é um chamado de madrugada.

Três testes, três respostas do servidor

```
PS C:\WINDOWS\system32> ssh -p 6969 nighthawk@192.168.56.103 "hostname; date; id"
*****
                AVISO DE ACESSO RESTRITO
Este sistema e de uso exclusivamente autorizado. Toda a atividade e registrada e monitorada.
O acesso ou uso nao autorizado e proibido e sujeito as sancoes da Lei 12.737/2012
(art. 154-A doCodigo Penal). Ao prosseguir, voce declara estar autorizado e concorda com
o monitoramento.
*****
Enter passphrase for key 'C:\Users\Mathy/.ssh/id_ed25519':
rhel-grupo1
sáb 19 set 2026 19:20:04 -03
uid=1000(nighthawk) gid=1000(nighthawk) grupos=1000(nighthawk),10(wheel),1001(ssh-admins) contexto=unconfined_u:unconfined_r:
-----
PS C:\WINDOWS\system32> ssh -p 6969 -o PubkeyAuthentication=no -o PreferredAuthentications=password nighthawk@192.168.56.103
nighthawk@192.168.56.103: Permission denied (publickey,gssapi-keyex,gssapi-with-mic).
```

1 • Chave ed25519

entra; o id mostra o grupo ssh-admins

2 • Senha forçada

Permission denied, sem pedir senha

3 • teste-negado, chave válida

barrado pelo AllowGroups (journal abaixo)

```
journal: User teste-negado from 192.168.56.1 not allowed because none of user's groups are listed in AllowGroups
```

O servidor já é pós-quântico?

DEFAULT : NO - SHA1

não existe no RHEL 10.2 — a DEFAULT já recusa SHA-1

FUTURE

oferece só ML-KEM → Windows: no matching key exchange method

DEFAULT

já oferece mlkem768x25519-sha256 + clássicos → Windows: curve25519

Print — política FUTURE, cliente OpenSSH do Windows:

```
PS C:\WINDOWS\system32> ssh -p 6969 nighthawk@192.168.56.103 "echo FUTURE ok"
Unable to negotiate with 192.168.56.103 port 6969: no matching key exchange method found. Their offer: mlkem768x25519-sha256,mlkem768nistp256-sha256,mlkem1024nistp384-sha384,ext-info-s,kex-strict-s-v00@openssh.com
```

Sigilo da sessão

Pós-quântico (ML-KEM, NIST FIPS 203) para clientes que suportam

Autenticação

Ainda clássica (ssh-ed25519) — assinatura pós-quântica não está no OpenSSH em produção

Decisão: DEFAULT — política do sistema, não do serviço

ssh-audit-harden.sh

--audit

Lê sshd -T: 20 diretivas + AllowGroups + Port

--apply

Drop-in 01-, backup, sshd -t, reload e confere o resultado

--rollback

Restaura o último backup e revalida

Lê o que o servidor usa, não o que o arquivo diz

- Fonte da verdade: sshd -T (configuração efetiva)
- Nunca edita o sshd_config: grava um drop-in próprio, com backup
- sshd -t antes do reload; sessões abertas não caem

Códigos de saída

- 0 sucesso
- 1 achado
- 2 erro de uso
- 3 dependência

0 achado real: escrito ≠ efetivo

```
[nighthawk@rhel-grupo1 ~]$ sudo /usr/local/sbin/ssh-audit-harden.sh --audit ; echo "exit$?"
2026-09-20 20:13:37 [INFO] Dependencias verificadas: 10 binarios presentes.
2026-09-20 20:13:37 [INFO] Iniciando ssh-audit-harden.sh v1.0.0 no modo audit.
2026-09-20 20:13:37 [INFO] Configuracao efetiva lida com sshd -T.

DIRETIVA          ATUAL          ESPERADO          SITUACAO
=====
AllowAgentForwarding no             no                CONFORME
AllowTcpForwarding no             no                CONFORME
Banner             /etc/issue.net /etc/issue.net    CONFORME
ClientAliveCountMax 2              0..2             CONFORME
ClientAliveInterval 300            1..300           CONFORME
Compression        no             no                CONFORME
GatewayPorts       no             no                CONFORME
HostbasedAuthentication no            no                CONFORME
IgnoreRhosts       yes            yes                CONFORME
KbdInteractiveAuthentication no            no                CONFORME
LoginGraceTime     30            1..30            CONFORME
LogLevel           VERBOSE       VERBOSE          CONFORME
MaxAuthTries       3             1..3             CONFORME
MaxSessions        4             1..4             CONFORME
PasswordAuthentication no            no                CONFORME
PermitEmptyPasswords no            no                CONFORME
PermitRootLogin    no            no                CONFORME
PermitUserEnvironment no            no                CONFORME
PubkeyAuthentication yes            yes                CONFORME
X11Forwarding      yes            no                NAO-CONFORME
AllowGroups        ssh-admins    ssh-admins        CONFORME
Port               6969         nao-padrao        CONFORME
=====

2026-09-20 20:13:38 [WARN] Auditoria concluida: 1 achado(s) fora da baseline.
exit1
[nighthawk@rhel-grupo1 ~]$
```

Print de 20/09 — o mesmo achado está registrado em 21-audit-antes.txt

```
$ sudo grep -rn X11Forwarding ...
.../50-redhat.conf:10: yes
.../99-hardening-grupo1.conf:15: no
```

- audit X11Forwarding yes • exit 1
- grep 50-redhat.conf é lido antes do 99-
- 99- → 01- renomeado • sshd -t • restart
- audit nenhum achado
- apply backup • sshd -t • reload
- apply de novo: idempotente

Onde ele se encaixa

Ferramenta	Cobre	Não cobre
ssh-audit	Varredura remota de algoritmos e banners	A configuração efetiva lida localmente
OpenSCAP	Sistema inteiro, perfis CIS e STIG	Correção reversível e granular
Ansible hardening	Frota inteira, idempotente por natureza	Exige infraestrutura de automação
ssh-audit-harden.sh	Leitura local, correção reversível, autocontido	Um host por vez

Testar no servidor real gerou a v1.1.0 — validada na própria VM em 23/09: porta preservada quando falta --porta e aviso quando outro arquivo tem precedência sobre o drop-in.

1

MÚLTIPLA ESCOLHA

Por que /boot fica fora do container LUKS?

- a Porque o XFS não pode ser criptografado
- b Porque o GRUB precisa ler kernel e initramfs antes de existir qualquer chave
- c Porque /boot não contém dados sensíveis
- d Porque o UEFI exige partições não criptografadas em todo o disco

Resposta: b

Pergunta 1

A cadeia de boot é o limitante: o GRUB carrega kernel e initramfs antes de qualquer chave existir.

- a) XFS pode ser criptografado — está dentro do LUKS em todos os outros volumes
- c) /boot guarda kernel e initramfs; adulterá-los compromete o sistema inteiro
- d) confunde a exigência do ESP em FAT32 com o /boot

Este é o risco residual do nosso esquema — e nós sabemos qual é.

2

MÚLTIPLA ESCOLHA

Aplicamos noexec em /tmp. Qual afirmação está correta?

- a** Nenhum código consegue mais ser executado a partir de /tmp
- b** Um script em /tmp ainda roda via bash /tmp/script.sh
- c** noexec impede a escrita de arquivos em /tmp
- d** noexec só funciona com o SELinux em Permissive

Resposta: b

Pergunta 2

noexec impede executar o arquivo. Quando se invoca o interpretador, quem executa é o bash — e ele tem permissão.

- a) o controle tem limite conhecido; não é bala de prata
- c) escrita é controlada por permissão de diretório, não por noexec
- d) as duas proteções são independentes e somam

Foi exatamente o que testamos e documentamos.

3

MÚLTIPLA ESCOLHA

Porta 6969 no sshd_config e no firewalld — e o sshd não sobe. Causa provável, com SELinux em Enforcing?

- a O kernel bloqueia portas acima de 1024
- b A porta não recebeu o rótulo ssh_port_t
- c O sshd só aceita portas listadas em /etc/services
- d O firewalld precisa ser desativado para portas não padrão

Resposta: b

Pergunta 3

semanage port -a -t ssh_port_t -p tcp 6969 — a negação aparece no ausearch

- a) não existe esse bloqueio de faixa no kernel
- c) /etc/services é apenas um mapa de nomes, não um controle
- d) é a "solução" errada mais aplicada no mundo real

Desligar o SELinux para resolver custa -10 pontos neste trabalho.

O volume group foi criado ocupando 100% do espaço disponível. Meses depois, /var/log encheu durante um incidente.

Por que a decisão de não deixar espaço livre transformou um problema operacional em um problema de resposta a incidente?

Responda em até três linhas • cobra raciocínio, não memorização de comando

Sem espaço livre no VG, não há como estender /var/log a quente — a saída vira parar serviço ou apagar log.

- Apagar log durante um incidente destrói a evidência de que se precisa para investigar
- Também não há snapshot para congelar o estado do sistema antes de mexer nele
- Espaço livre no VG é controle de disponibilidade E de preservação de evidência

Critério: 1 ponto extensão a quente • 1 ponto perda de evidência • 1 ponto snapshot.

Nosso servidor usa LVM sobre LUKS com uma única passphrase digitada no console a cada boot.

Por que esse desenho é inadequado para um datacenter com centenas de servidores, e qual alternativa você proporia?

Responda em até três linhas • cobra raciocínio, não memorização de comando

Reinício não assistido é impossível: toda queda de energia vira intervenção humana, servidor a servidor.

- Não escala e não funciona em sítio remoto ou máquina sem console acessível
- Alternativa: desbloqueio vinculado à rede (Clevis + Tang / NBDE) ou selamento em TPM2
- O disco só abre dentro do perímetro esperado

Critério: 1,5 ponto por que não escala • 1,5 ponto alternativa coerente.

Para levar

Segurança é configuração, não instalação.

O instalador não aplicou nenhuma opção de montagem e o OpenSSH não veio endurecido.
E testar mostrou o que nenhum guia mostra: configuração escrita não é configuração efetiva.
Tudo está documentado, com evidência, no repositório.

`github.com/<org>/grupo1-rhel`

Obrigado. Perguntas?